

SGSI-REG-006 — Registro de No Conformidades, Deuda de Diseño y Acciones Correctivas

Organización: Atalaya Gestión Patrimonial SL

Código de documento	SGSI-REG-006
Versión	1.9
Estado	Revisión documental pendiente de aprobación
Clasificación	Confidencial
Propietario	Dirección General — Atalaya GP SL
Autor	El consultor (externo)
Emisión v1.0	24/07/2026
Revisiones v1.1 a v1.7	24/07/2026, 20/08/2026 y 22/08/2026
Revisión v1.8	23/08/2026
Aprobación revisión 1.9	Pendiente conforme a DOC-002 §4; sin acta de aprobación de esta revisión

Objeto
Registro previsto en SGSI-DOC-010 §4. Recoge los incumplimientos de requisitos del SGSI, su análisis de causa y las acciones correctivas asociadas, con su verificación de eficacia (cláusula 10.2).

Dos hojas y por qué están separadas

«No conformidades» registra incumplimientos de requisitos exigibles, también durante la implantación. «Deuda de diseño» conserva las acciones aún pendientes y su trazabilidad. La ausencia de auditoría no excluye una no conformidad. HD-08 se vincula al incumplimiento documental identificado en la revisión; no se simula una auditoría ni una ejecución.

Reglas de uso

- 1. Una acción sin verificación de eficacia no cierra la no conformidad: la esconde. El campo de verificación es obligatorio.
 - 2. El análisis de causa pregunta qué del sistema permitió el fallo, no quién falló (regla de no represalia, DOC-003).
 - 3. Si la causa apunta a un escenario mal valorado, obliga a re-evaluarlo (DOC-004 §8) y a registrarlo en la columna correspondiente.
 - 4. Primero se contiene el efecto, después se analiza la causa.
- La clasificación depende de la exigibilidad del requisito. El vencimiento de un plazo obliga a revisar el incumplimiento, pero no aplaza obligaciones ya aplicables. No se cierra una acción sin verificar su eficacia.

Historial de versiones

Versión	Fecha	Descripción del cambio
1.6	20/08/2026	Alta de la entrada HD-08 en esta hoja (el MSP opera como encargado del tratamiento de facto sin contrato conforme al art. 28 RGPD), reflejada también en SGSI-DOC-010 v1.9 §4.1. Hallazgo identificado al construir SGSI-REG-008, tratamiento T-10.
1.7	22/08/2026	Ampliación del alcance de HD-01, que pasa de doce a trece controles con el alta de A 8.21, retirado de su anexo de soporte contractual en SGSI-DOC-006 v1.5. HD-08: se anota el alta del borrador SGSI-ACU-003 v0.1 (anexo de encargado del tratamiento con el MSP, art. 28 RGPD), redactado el 23/08/2026 y pendiente de aprobación del Comité y de firma por el MSP. El hallazgo NO se cierra: conforme a la regla de uso 1 de esta misma hoja («una acción sin verificación de eficacia no cierra la no conformidad, la esconde») y a DOC-010 §4, el borrador no es la acción determinada — formalizar el contrato— sino su preparación. Estado permanece Abierta; plazo sin cambios (20/11/2026). Sin otras altas, bajas ni cierres de hallazgos.
1.8	23/08/2026	

Historial completo v1.0-1.5 en SGSI-REG-006 v1.7 (sin cambios respecto de esa versión).

Revisión de septiembre: NC-2026-001 vinculada a HD-08; altas HD-09 y HD-10. Todas abiertas, sin evidencia de eficacia. No cambian la fecha de corte ni los cierres históricos.

Historial 1.9 | 20/09/2026 | Autor del caso | Corrección de coherencia y legibilidad. Deltas en correcciones_2026-09.md. Sin aprobación formal ni eficacia operativa declarada.

ID	Fecha detección	Origen	Clasificación	Descripción del incumplimiento	Requisito incumplido	Reacción inmediata	Análisis de causa	Acción correctiva	Responsable	Plazo	Verificación de eficacia	Fecha verificación	Estado	¿Obliga a re-evaluar escenario?	HD de origen
NC-2027-001 (ejemplo)		Revisión de registros	Menor	Ejemplo de formato. Sustitúyase por una no conformidad real.	Cláusula o control del Anexo A	Qué se hizo para contener el efecto antes de analizar la	Qué del sistema permitió el fallo. No quién falló.	Acción dirigida a la causa, no al síntoma.	Rol responsable	dd/mm/aaaa	Cómo se comprueba que la acción funcionó, vencido el plazo.	dd/mm/aaaa	Abierta		
NC-2026-001	20/09/2026	Revisión documental del caso ficticio	Incumplimiento documental	HD-08 describe acceso del MSP a datos sin contrato de encargo.	RGPD art. 28; A.5.20/A.5.31/A.5.34	Reconocer la carencia y mantener la acción abierta; no presentar el borrador como contrato.	La revisión contractual no identificó la relación de encargo antes del acceso descrito.	Formalizar encargo y verificar obligaciones, región de alojamiento y eficacia.	Dirección General	20/11/2026	Pendiente de ejecución y verificación; no se declara eficacia.		Abierta	Revisar riesgos de acceso y privacidad sin alterar valoraciones por esta anotación.	HD-08

ID	Fecha alta	Hallazgo	Origen del hallazgo	Tratamiento comprometido	Responsable	Plazo	Estado	Fecha de cierre	Si vence sin cierre
HD-01	24/07/2026	Trece controles del Anexo A declarados aplicables descansan en una práctica no escrita, sin documento del SGSI ni control del registro que los soporte: A 5.6, 5.29, 5.32, 6.1, 6.2, 7.5, 7.11, 8.6, 8.7, 8.12, 8.19, 8.21 y 8.23.	Trazabilidad de la Declaración de Aplicabilidad (SGSI-REG-003, columna «Controles»).	Asignar a cada uno un documento o un control del registro, o reclasificar su aplicabilidad con justificación escrita.	Responsable del SGSI	24/10/2026	Abierta		Alta como no conformidad menor por incumplimiento de la cláusula 8.1: los controles están determinados, justificados y con su estado declarado en la Declaración de Aplicabilidad, que es lo que exige 6.1.3 d); lo que falta es implementar las acciones determinadas.
HD-02	24/07/2026	Dos escenarios de nivel Alto no alcanzan la cobertura convergente exigida en SGSI-DOC-004 §6 con el tratamiento diseñado: RSC-004 no tiene previsto ningún control en el dominio físico y RSC-016 se trata con un único control organizativo.	Verificación de la regla de convergencia sobre el registro v1.1.	Rediseñar el tratamiento incorporando el control que falta en cada dominio, o documentar la excepción ante el Comité con justificación escrita.	Propietarios de los riesgos	24/09/2026	Abierta		Alta como no conformidad menor por incumplimiento de la metodología aprobada.
HD-03	24/07/2026	Existen controles físicos contratados y operativos cuya ejecución no deja evidencia registrada, por lo que su eficacia no es verificable (RSC-018).	Aportación del jefe de seguridad en la revisión del catálogo de escenarios.	Implantar los registros de ejecución previstos en PT-11 y medir su cumplimiento mediante el objetivo O8 (DOC-005).	Jefe de seguridad	24/09/2026	Abierta		Alta como no conformidad mayor: afecta a controles de riesgos de nivel Crítico.
HD-04	24/07/2026	Cinco escenarios del registro no se situaban en ninguna interfaz declarada del alcance, incumpliendo la regla de completitud de SGSI-DOC-004 §5.1.	Verificación cruzada entre SGSI-REG-001 y SGSI-DOC-001 §7.4.	Corregido en dos pasos: alta de cuatro interfaces en SGSI-DOC-001 §7.4 y normalización de la columna «Interfaz» de SGSI-REG-001 al vocabulario de las diez interfaces declaradas.	Responsable del SGSI	30/09/2026	Cerrada	24/07/2026	No procede: hallazgo cerrado.
HD-05	24/07/2026	Cuatro escenarios carecían de objetivo de seguridad asociado, dos de ellos desde la primera versión del cuadro de objetivos.	Verificación cruzada entre SGSI-REG-001 y SGSI-DOC-005.	Corregido en la propia revisión mediante el alta de los objetivos O11 y O12 en SGSI-DOC-005.	Comité de Seguridad Convergente	30/09/2026	Cerrada	24/07/2026	No procede: hallazgo cerrado.
HD-06	24/07/2026	La Declaración de Aplicabilidad y el registro de riesgos empleaban vocabularios de estado distintos, y cinco controles del Anexo A figuraban como implantados mientras los controles del registro que los soportan estaban planificados.	Verificación cruzada entre SGSI-REG-003 y SGSI-REG-001 (hoja «Controles»).	Vocabulario unificado y regla de coherencia declarada en ambos documentos. Pendiente de incorporar la comprobación al validador automático.	Responsable del SGSI	24/10/2026	Abierta		Alta como no conformidad menor: la comprobación automática de coherencia seguiría sin existir.
HD-07	20/08/2026	La clasificación de SGSI-REG-001 (Confidencial) no era coherente con su propio contenido: la portada declara «la relación completa de vulnerabilidades del sistema de protección de la familia», definición literal de Restringida en SGSI-DOC-002 §5. El mismo desajuste afectaba a esta hoja y a SGSI-DOC-010 §4.1.	Revisión de clasificación de agosto de 2026, por aplicación de la regla del nivel superior de SGSI-DOC-002 §5.	Reclasificado SGSI-REG-001 a Restringida y SGSI-REG-006 y SGSI-DOC-010 a Confidencial, en esta misma revisión.	Responsable del SGSI	20/08/2026	Cerrada	20/08/2026	No procede: hallazgo cerrado.
HD-08	20/08/2026	El MSP tiene acceso administrativo a datos sin contrato de encargo conforme al art. 28 RGPD. La falta actual se reconoce dentro del escenario ficticio. El borrador pasa a SGSI-ACU-004 v0.2 para resolver la colisión con el acuerdo de confidencialidad de la representante. No está aprobado ni firmado. Región de alojamiento y eficacia pendientes.	Construcción de SGSI-REG-008 (Registro de Actividades de Tratamiento), tratamiento T-10.	Formalizar SGSI-ACU-004 mediante revisión de Dirección General y asesoría legal, aprobación por Dirección General y firma bilateral. Verificar alojamiento y obligaciones efectivamente cumplidas. Vinculado a NC-2026-001.	Dirección General	20/11/2026	Abierta		NC-2026-001 documenta la carencia ya identificada; el plazo 20/11/2026 es de tratamiento, no una exención del art. 28.
HD-09	20/09/2026	C-039/C-044 en papel no cubren DIGITAL en RSC-019/RSC-020.	Revisión documental de septiembre	Rediseñar o justificar tratamiento con medios del escenario; actualizar planes y residual. No introducir sistemas para forzar cobertura.	Dirección General	Antes de operación del tratamiento afectado	Abierta		Evaluar según requisito y exigibilidad; no convertir el plazo en exención.
HD-10	20/09/2026	Justificación residual de EIPD y precisiones RAT, plazos laborales, geolocalización y roles de proveedores pendientes.	Revisión documental de septiembre	Validar cada finalidad y base, medidas y residual antes de operación; decidir consulta previa según art. 36. No declarar consulta ni mitigación ya realizadas.	Dirección General	Antes de operación del tratamiento afectado	Abierta		Evaluar según requisito y exigibilidad; no convertir el plazo en exención.